NIST Cybersecurity Framework aplicado à Plataforma de Conexão de Currículos

1. **Identificar (Identify – ID)**

A função **Identificar** envolve compreender os riscos de segurança cibernética relacionados aos sistemas, dados e ativos da organização.
O objetivo é **identificar ativos críticos, riscos e o contexto do negócio**, criando uma base para o programa de segurança da informação.

ID.AM – Gerenciamento de Ativos
A empresa mantém um inventário dos ativos tecnológicos utilizados para o desenvolvimento e operação da plataforma de conexão de currículos.
Hardware

ID	Equipamento	Qtd	Especificação	Usuário / Setor
HW01	Desktop / Notebook	5	16GB RAM, 512GB	Funcionários
HW02	Monitores	10	24” Full HD	Funcionários
HW03	Smartphones Android	2	Android versão atual	Testes de aplicativos
HW04	iPhone	1	iOS atualizado	Testes de aplicativos
HW05	Tablet	1	Android ou iPad	Testes de interface
HW06	Roteador Wi-Fi	1	Roteador empresarial	Rede da empresa
HW07	Switch de rede	1	8 portas Gigabit	Conectividade
HW08	No-break	1	1200VA	Proteção de energia
HW09	Impressora multifuncional	1	Impressão / digitalizar	Escritório
HW10	TV SMART	1	40–50”	Reuniões

Software

ID	Software	Tipo	Função
SW01	Visual Studio Code	Desenvolvimento	Programação de apps e websites
SW02	Android Studio	Desenvolvimento	Desenvolvimento de apps Android
SW03	Node.js	Backend	Desenvolvimento de servidores
SW04	MySQL	Banco de Dados	Armazenamento de dados
SW05	Git	Controle de versão	Gerenciamento de código
SW06	GitHub	Repositório	Armazenamento de código
SW07	Figma	Design	Criação de interfaces
SW08	Google Chrome	Navegação	Teste de websites
SW09	Docker	Infraestrutura	Execução de aplicações
SW10	Amazon Web Services	Cloud	Hospedagem do sistema

Sistemas Principais

Plataforma de cadastro de currículos
Sistema de match entre candidatos e vagas
Painel de recrutadores e empresas
Portal de candidatos
Website institucional

ID.BE – Ambiente de Negócios
A empresa atua no setor de **tecnologia de recrutamento (HRTech)**, desenvolvendo uma plataforma digital que conecta:

I. empresas que buscam contratar profissionais
II. pessoas desempregadas que procuram trabalho
III. profissionais que desejam melhorar sua carreira

A plataforma permite:

I. cadastro de currículos
II. busca inteligente de candidatos
III. publicação de vagas
IV. recomendação automática de oportunidades
V. análise de compatibilidade entre perfil e vaga

O sistema manipula **dados pessoais e profissionais**, sendo necessário alto nível de segurança e conformidade com a **Lei Geral de Proteção de Dados (LGPD)**.

ID.GV – Governança

A governança de segurança da informação é baseada em políticas internas que definem:

I. regras de acesso aos sistemas
II. responsabilidades dos funcionários
III. proteção de dados sensíveis

Principais práticas:

I. login individual para cada funcionário
II. autenticação em dois fatores (2FA)
III. acesso restrito a servidores e banco de dados
IV. políticas de segurança e backup

ID.RA – Avaliação de Risco

A empresa realiza avaliação de riscos considerando as principais ameaças ao sistema.

Exemplos de riscos

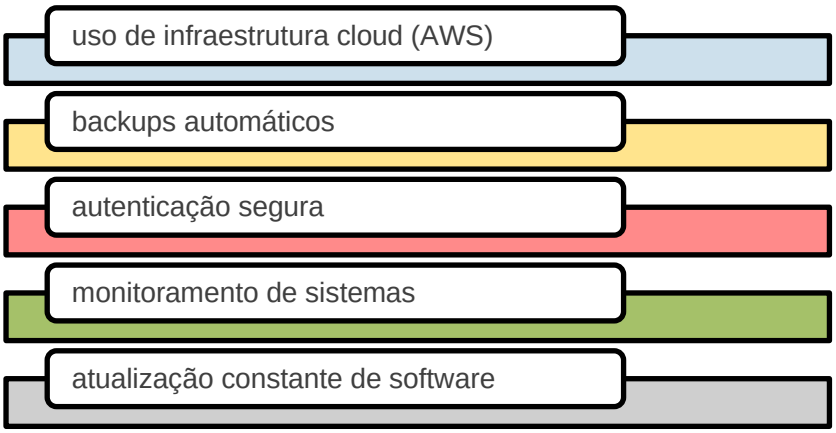
Ameaça	Vulnerabilidade	Possível Impacto
Ataque hacker	Senhas fracas	Invasão do sistema
Malware	Falta de antivírus atualizado	Roubo de informações
Erro humano	Falta de controle de acesso	Exclusão de dados
Queda de energia	Falta de no-break	Interrupção do sistema
Falha do servidor	Falta de backup	Violação da LGPD

Riscos prioritários identificados:

- vazamento de dados de usuários
- perda do banco de dados
- acesso indevido ao código fonte

ID.RM – Estratégia de Gerenciamento de Risco

Para reduzir os riscos, a empresa adota:

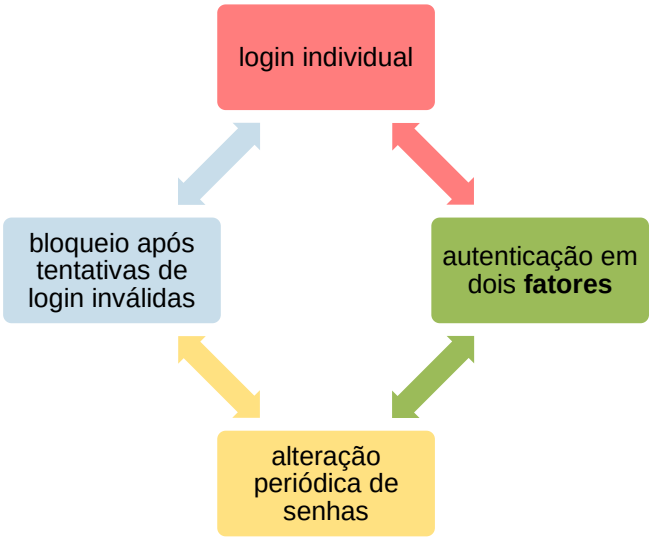


2. Proteger (Protect – PR)
A função **Proteger** envolve a implementação de controles de segurança para proteger os ativos e dados da organização.

PR.AC – Controle de Acesso
O acesso aos sistemas é definido conforme a função do funcionário.

Função	Acesso
Desenvolvedor Backend	Servidor e banco de dados
Desenvolvedor Mobile	Código do aplicativo
Desenvolvedor Web	Interface e website
Designer UX/UI	Ferramentas de design
Gerente de Projeto	Painéis administrativos

Outras medidas:



PR.AT – Conscientização e Treinamento

boas práticas de segurança

uso seguro de sistemas

proteção de dados pessoais

prevenção de ataques cibernéticos

PR.DS – Segurança de Dados

Medidas adotadas para proteção das informações:

I. criptografia de dados sensíveis
II. uso de conexão segura HTTPS
III. controle de acesso ao banco de dados
IV. backup automático diário

Dados protegidos incluem:

I. currículos dos usuários
II. dados pessoais e profissionais
III. histórico de candidaturas
IV. dados das empresas cadastradas
V. código fonte da plataforma

PR.IP – Processos de Proteção da Informação

A empresa possui processos formais para proteção da informação, incluindo:

gestão de acessos

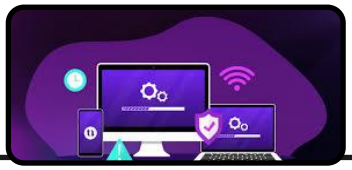
políticas de backup

controle de alterações no código

PR.MA – Manutenção

A manutenção dos sistemas inclui:

atualização periódica de softwares



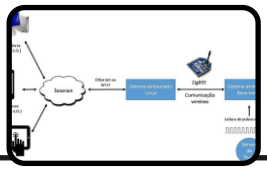
aplicação de patches de segurança

manutenção da infraestrutura cloud

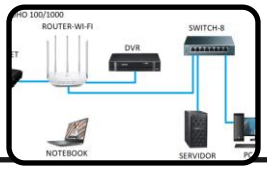
PR.PT – Tecnologia de Proteção
Tecnologias utilizadas:

antivírus Microsoft Defender

firewall no roteador



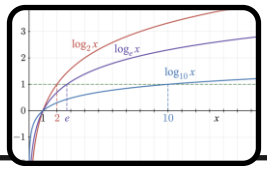
monitoramento da rede



proteção da infraestrutura cloud

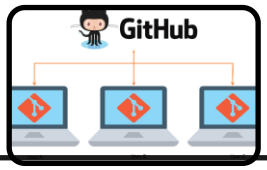
3. Detectar (Detect – DE)
A função **Detectar** envolve identificar rapidamente eventos de segurança.

DE.CM – Monitoramento Contínuo
A empresa realiza monitoramento por meio de:

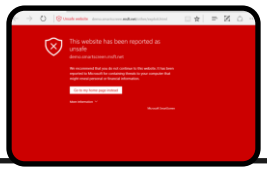


logs de acesso aos sistemas

monitoramento da infraestrutura cloud



monitoramento de repositórios de código



verificação de atividades suspeitas

DE.DM – Processos de Detecção

Os processos de detecção incluem:

4. Responder (Respond – RS)
Esta função envolve ações tomadas após a detecção de um incidente de segurança.

RS.RP – Planejamento de Resposta
A empresa possui procedimentos para:

- **identificar a origem do incidente**
  A origem é identificada por meio da análise de logs do sistema (acessos, autenticação e requisições), correlacionando informações como IP, usuário, horário e ações realizadas, permitindo rastrear o ponto inicial do ataque.
- **isolar sistemas comprometidos**
  O isolamento é feito bloqueando acessos suspeitos (IP ou usuário), desativando temporariamente serviços afetados e interrompendo conexões com partes comprometidas do sistema para evitar propagação do incidente.
- **restaurar serviços afetados**
  Os serviços são restaurados por meio de reinicialização dos sistemas, aplicação de correções emergenciais e, se necessário, restauração de versões estáveis ou backups recentes.

RS.CO – Comunicação
Durante incidentes são realizadas comunicações com:

- equipe técnica
- gestores
- empresas clientes

A comunicação é realizada por meio de canais internos (e-mail, sistemas de alerta ou mensageria), com relatórios objetivos sobre o incidente, seu impacto e ações em andamento. Caso necessário, os usuários afetados são informados de forma clara, especialmente em casos que envolvam dados ou acesso à conta.

RS.AN – Análise
Após um incidente é realizada análise para identificar:

- **causas do problema**

Refere-se à identificação da falha que originou o incidente, como erro de configuração, falha de código ou ausência de controle de segurança.

- **vulnerabilidades exploradas**
  São as brechas utilizadas no sistema, como falhas de validação, autenticação fraca ou ausência de proteção contra ataques.
- **impacto causado**
  Corresponde às consequências do incidente, como indisponibilidade do sistema, perda de dados, vazamento de informações ou prejuízo operacional.

RS.MI – Mitigação
Medidas aplicadas:

- **correção de vulnerabilidades**
  Ajuste no código ou configuração para eliminar a falha explorada.
- **atualização de sistemas**
  Aplicação de patches e atualizações de segurança em softwares e dependências.
- **alteração de credenciais comprometidas**
  Redefinição de senhas, tokens e chaves de acesso que possam ter sido expostos.

RS.IM – Melhorias
Após incidentes, os processos de segurança são revisados e aprimorados.

5. Recuperar (Recover – RC)
A função **Recuperar** envolve restaurar sistemas após incidentes.

RC.RP – Planejamento de Recuperação
A empresa possui plano de recuperação baseado em:

- **backups automáticos diários**
  Cópias periódicas dos dados são realizadas automaticamente para garantir recuperação em caso de falha.
- **armazenamento em cloud**
  Os backups são armazenados em ambientes seguros na nuvem, garantindo disponibilidade e proteção contra perda local.
- **redundância de dados**
  Os dados são replicados em múltiplos locais ou servidores, garantindo continuidade do serviço mesmo em caso de falha.

RC.IM – Melhorias
Após a recuperação são realizadas melhorias como:

- **revisão de políticas de segurança**
  Atualização das diretrizes e práticas de segurança com base no incidente ocorrido.
- **aprimoramento dos controles de acesso**
  Fortalecimento de autenticação, permissões e monitoramento de usuários.
- **melhorias no sistema de backup**
  Ajustes na frequência, armazenamento e testes de restauração dos backups.

RC.CO – Comunicação
Após a recuperação, são feitas comunicações para:

- **equipe interna**
- **empresas parceiras**
- **usuários da plataforma**

São enviados comunicados formais informando a normalização dos serviços, as medidas adotadas e, quando necessário, orientações de segurança para os usuários.